

Bedrohungen und Angriffsvektoren

IT-SICHERHEIT / SEMESTER 1 UND 2



1

AGENDA

- 01 BEGRIFFE
- 02 SICHERE PASSWÖRTER
- 03 MULTIFAKTOR
- 04 PASSWORDLESS
- 05 ÜBUNG

2

01

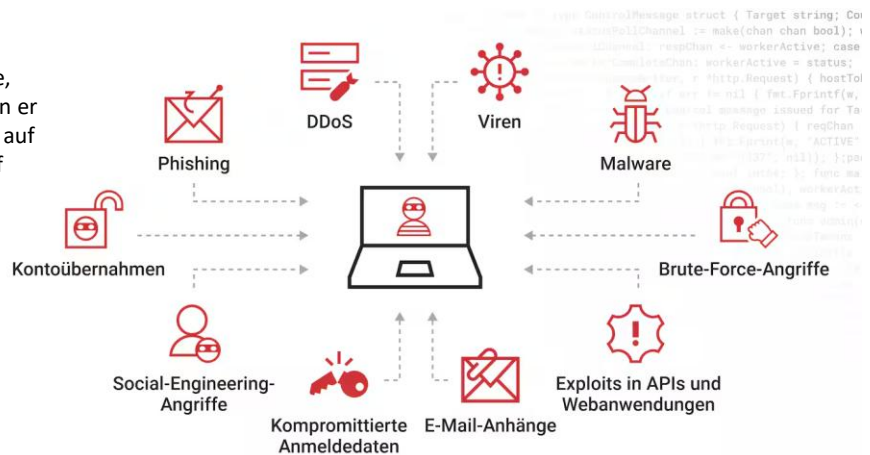
Begriffe

3

IT-SICHERHEIT / SEMESTER 1 UND 2

Arten von Angriffsvektoren

Ein Angriffsvektor ist die Methode, die ein Angreifer verwendet, wenn er versucht, unrechtmäßigen Zugriff auf ein IT-System zu erlangen und auf vertrauliche Informationen zuzugreifen.



Häufige Arten von Angriffsvektoren



[Quelle: <https://www.akamai.com/de/glossary/what-is-attack-vector> - letzter Abruf 07.09.2025]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

4

4

10 gängige Bedrohungen der Informationssicherheit

- Insider Bedrohungen
- Viren und Würmer
- Botnetze
- Drive-by Download
- Phishing
- DDoS
- Ransomware
- Exploit-Kits
- APT (Advanced Persistent Thread)
- Malvertising



[Quelle: <https://www.computerweekly.com/de/feature/Die-10-gaengigsten-Bedrohungen-der-Informationssicherheit> - letzter Abruf 07.09.2025]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

5

5

[1] Insider Bedrohungen

Eine Insider-Bedrohung liegt vor, wenn **Personen, die einer Organisation nahestehen** und autorisierten Zugang zum Netzwerk haben, diesen Zugang absichtlich oder unabsichtlich missbrauchen, um die kritischen Daten oder Systeme der Organisation negativ zu beeinflussen.

Beispiele:

- Unvorsichtige Mitarbeiter, die sich nicht an die Vorschriften und Richtlinien ihres Unternehmens halten
 - versehentlich Kundendaten per E-Mail an Externe versenden
 - auf Phishing-Links in E-Mails klicken
 - Anmeldeinformationen an andere weitergeben.
- Lieferanten, Auftragnehmer, Geschäftspartner und Drittanbieter sind eine weitere Quelle für Insider-Bedrohungen.
- Einige Insider umgehen die Sicherheitsmaßnahmen **absichtlich aus Bequemlichkeit oder aus unüberlegten Versuchen**, produktiver zu arbeiten.
- **Böswillige Insider umgehen absichtlich Sicherheitsprotokolle**, um Daten zu löschen, Daten zu stehlen, um sie später zu verkaufen oder zu nutzen, den Betrieb zu stören oder dem Unternehmen anderweitig zu schaden.



[Quelle: <https://www.computerweekly.com/de/feature/Die-10-gaengigsten-Bedrohungen-der-Informationssicherheit> - letzter Abruf 07.09.2025]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

6

6

[1] Wie man sich vor Insider-Bedrohungen schützt

- **Beschränken Sie den Zugriff der Mitarbeiter auf die Ressourcen**, die sie für ihre Arbeit benötigen.
- **Schulen Sie neue Mitarbeiter und Auftragnehmer in Sicherheitsfragen**, bevor Sie ihnen den Zugang zum Netz ermöglichen.
- **Integrieren Sie Informationen über unbeabsichtigte und bössartige Insider-Bedrohungen** in regelmäßige Sicherheitsschulungen.
- **Richten Sie Auftragnehmern und anderen Freiberuflern zeitlich begrenzte Konten ein**, die zu bestimmten Terminen auslaufen, zum Beispiel zu den Terminen, an denen ihre Verträge enden.
- **Implementierung einer Zwei-Faktor-Authentifizierung**, bei der jeder Benutzer zusätzlich zum Passwort eine zweite Identifikationsinformation angeben muss.
- **Installieren Sie Monitoring-Software**, um das Risiko von Datenschutzverletzungen und des Diebstahls von geistigem Eigentum zu verringern, indem Sie unvorsichtige oder böswillige Insider identifizieren.
 - Hierbei gilt es die strengen gesetzlichen Vorschriften bei überwachender Software zu beachten, wie beispielsweise beim Datenschutz
 - Alle Beteiligten im Unternehmen wie Betriebsrat, Rechtsabteilung und Personalabteilung mit ins Boot nehmen

7

Drei Kategorien von Insider-Bedrohungen



Kompromittiert

Bedrohungsakteure, die die Anmeldeinformationen eines legitimen Mitarbeiters gestohlen haben, geben sich als autorisierte Benutzer aus und nutzen ihre Konten, um sensible Daten zu exfiltrieren. Mitarbeiter wissen oft nicht, dass sie kompromittiert wurden.



Nachlässig

Mitarbeiter ohne die entsprechende Sicherheitsschulung können versehentlich vertrauliche Daten missbrauchen oder preisgeben, oft als Folge von Social Engineering, verlorenen/ gestohlenen Geräten oder falsch versendeten E-Mails/ Dateien.



Bösartig

Bösartige Akteure – wie derzeitige oder ehemalige Mitarbeiter, Drittparteien oder Partner – nutzen ihren privilegierten Zugriff, um geistiges Eigentum oder Unternehmensdaten für Betrug, Sabotage, Spionage, Rache oder Erpressung zu stehlen.

ILLUSTRATION: ANDREW_JEVAK/ADOBEE STOCK

©2020 TECHTARGET. ALLE RECHTE VORBEHALTEN. TechTarget

8

[2] Viren und Würmer

Viren und Würmer sind bössartige Softwareprogramme (Malware), die darauf abzielen, die Systeme, Daten und Netzwerke eines Unternehmens zu zerstören.

Virus

- Ein **Computervirus ist ein bössartiger Code**, der sich repliziert, indem er sich in ein anderes Programm, ein System oder eine Hostdatei kopiert.
- Er bleibt inaktiv, bis ihn jemand wissentlich oder versehentlich aktiviert** und die Infektion ohne das Wissen oder die Erlaubnis eines Benutzers oder der Systemverwaltung verbreitet.

Wurm:

- Ein **Computerwurm ist ein selbstreplizierendes Programm**, das sich nicht in ein Wirtsprogramm kopieren muss und keine menschliche Interaktion benötigt, um sich zu verbreiten.
- Seine Hauptfunktion besteht darin, **andere Computer zu infizieren**, während er auf dem infizierten System aktiv bleibt.
- Würmer **verbreiten sich oft über Teile des Betriebssystems**, die automatisch und für den Benutzer unsichtbar sind.
- Sobald ein Wurm in ein System eingedrungen ist, **beginnt er sofort, sich zu replizieren und infiziert Computer und Netzwerke**.



[Quelle: <https://www.computerweekly.com/de/feature/Die-10-gaengigsten-Bedrohungen-der-Informationssicherheit> - letzter Abruf 07.09.2025]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

9

9

[2] Wie man Viren und Würmern vorbeugt

- Unternehmen sollten auf allen ihren Systemen und vernetzten Geräten **Antiviren- und Antimalwaresoftware** installieren und diese Software auf dem neuesten Stand halten.
- Unternehmen müssen ihre Benutzer darin schulen, **keine Anhänge herunterladen** oder auf **Links in E-Mails** von unbekannten Absendern zu klicken und keine **kostenlose Software von nicht vertrauenswürdigen Websites** herunterladen.
- Auch bei der Nutzung von **P2P-Filesharing-Diensten** sollten die Benutzer sehr vorsichtig sein und nicht auf Werbung klicken, insbesondere nicht auf Werbung von unbekannten Marken und Websites.



[Quelle: <https://www.computerweekly.com/de/feature/Die-10-gaengigsten-Bedrohungen-der-Informationssicherheit> - letzter Abruf 07.09.2025]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

10

10

[3] Botnetze

Ein Botnetz ist eine Sammlung von mit dem Internet verbundenen Geräten, einschließlich PCs, Mobilgeräten, Servern und IoT-Geräten, die mit **einer gemeinsamen Art von Malware infiziert sind und ferngesteuert werden**.

- In der Regel sucht die Botnet-Malware **im gesamten Internet** nach anfälligen Geräten.
- Das Ziel der Bedrohungsakteure, die ein Botnet erstellen, besteht darin, **so viele angeschlossene Geräte wie möglich zu infizieren** und die Rechenleistung und Ressourcen dieser Geräte für automatisierte Aufgaben zu nutzen.
- Diese Aktivitäten bleiben den Benutzern der Geräte **im Allgemeinen verborgen** bleiben.
- Die Bedrohungsakteure - häufig Cyberkriminelle -, die diese Botnets kontrollieren, nutzen sie zum **Versenden von E-Mail-Spam**, zur **Durchführung von Klickbetrugskampagnen** und zur **Generierung von bösartigem Datenverkehr** für verteilte Denial-of-Service-Angriffe (DDoS).



[Quelle: <https://www.computerweekly.com/de/feature/Die-10-gaengigsten-Bedrohungen-der-Informationssicherheit> - letzter Abruf 07.09.2025]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

11

11

[3] Wie man sich vor Botnetzen schützt

- **Überwachen Sie die Netzwerkleistung und -aktivität**, um ein ungewöhnliches Netzwerkverhalten zu erkennen;
- Halten Sie die **Betriebssysteme auf dem neuesten Stand**;
- Halten Sie alle **Software auf dem neuesten Stand** und installieren Sie alle notwendigen Sicherheits-Patches;
- **Aufklärung der Nutzer, sich nicht an Aktivitäten zu beteiligen**, die sie dem Risiko von Bot-Infektionen oder anderer Malware aussetzen, einschließlich des Öffnens von E-Mails oder Nachrichten, des Herunterladens von Anhängen oder des Anklickens von Links aus unbekannten Quellen; und
- **Implementieren Sie Anti-Botnet-Tools**, die Bot-Viren aufspüren und blockieren. Darüber hinaus enthalten die meisten Firewalls und Antivirenprogramme grundlegende Tools zur Erkennung, Verhinderung und Entfernung von Botnets.



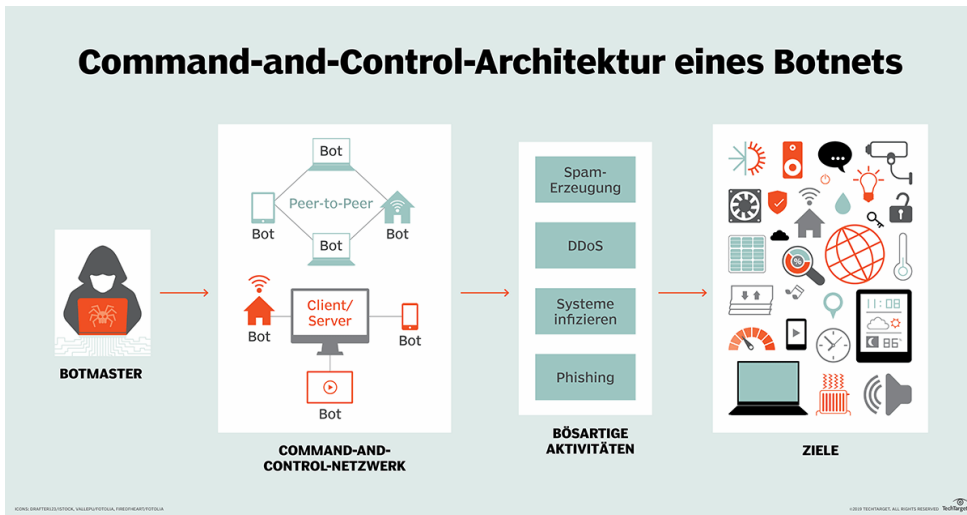
[Quelle: <https://www.computerweekly.com/de/feature/Die-10-gaengigsten-Bedrohungen-der-Informationssicherheit> - letzter Abruf 07.09.2025]

tgm | Technologisches Gewerbemuseum | Höhere technische Bundes-Lehr- und Versuchsanstalt

12

12

Command-and-Control-Architektur eines Botnets



13

[4] Drive-by-Download-Angriffe

Bei einem Drive-by-Download-Angriff wird **bösartiger Code von einer Website über einen Browser, eine Anwendung oder ein integriertes Betriebssystem ohne die Erlaubnis oder das Wissen des Benutzers heruntergeladen**.

- Der Benutzer muss auf nichts klicken, um den Download zu aktivieren. Schon das Aufrufen oder Durchsuchen einer Website kann einen Download auslösen.
- Cyberkriminelle können Drive-by-Downloads nutzen, um **Banking-Trojaner** einzuschleusen, **persönliche Daten zu stehlen** und zu sammeln sowie Exploit Kits oder andere Malware auf Endgeräte zu schleusen.

14

[4] Wie man Drive-by-Download-Angriffe verhindert

- **Systeme regelmäßig zu aktualisieren** und mit den neuesten Versionen von Software, Anwendungen, Browsern und Betriebssystemen zu versehen.
- Die Benutzer sollten auch gewarnt werden, sich von **unsicheren Websites fernzuhalten**.
- Die Installation von **Sicherheitssoftware, die Websites aktiv scannt**, kann dazu beitragen, Endgeräte vor Drive-by-Downloads zu schützen.

[5] Phishing-Angriffe

- Phishing-Angriffe sind eine Art von Bedrohung der Informationssicherheit, bei der **Social Engineering** eingesetzt wird, um Benutzer dazu zu bringen, die **üblichen Sicherheitspraktiken zu verletzen und vertrauliche Informationen preiszugeben**, zum Beispiel Namen, Adressen, Anmeldedaten, Kreditkarteninformationen und andere Finanzdaten.
- In den meisten Fällen verschicken Hacker gefälschte **E-Mails**, die so aussehen, als kämen sie von authentischen Quellen wie Finanzinstituten, eBay, PayPal und sogar von Freunden und Kollegen.

[5] Wie man Phishing-Angriffe verhindern kann

- Unternehmen sollten ihre Benutzer darin schulen, **keine Anhänge herunterzuladen oder auf Links in E-Mails von unbekannten Absendern zu klicken**
- Das **Herunterladen von kostenloser Software von nicht vertrauenswürdigen Websites** vermeiden.

Phishing vs. Spear-Phishing vs. Whaling

Whaling ist eine spezielle Art von Spear-Phishing, und Spear-Phishing ist eine spezielle Art von Phishing. Lernen Sie die Unterschiede unten kennen.

Phishing

Ein weit gefasster Begriff, der alle Arten von Angriffen umfasst, die versuchen, ein Opfer zu einer bestimmten Aktion zu verleiten. Hat kein spezifisches Ziel.



Spear-Phishing

Eine Art von Phishing, die auf Einzelpersonen abzielt.



Whaling

Eine Form des Spear-Phishings, die auf hochrangige Opfer innerhalb eines Unternehmens abzielt.



[6] DDoS-Angriffe (Verteilte Denial-of-Service-Angriffe)

Bei einem DDoS-Angriff (Distributed Denial of Service) greifen **mehrere kompromittierte Rechner ein Ziel**, zum Beispiel einen Server, eine Website oder eine andere Netzwerkressource, an und machen das **Ziel funktionsunfähig oder schränken die Funktionalität stark ein**.

- Die **Flut von Verbindungsanfragen**, eingehenden Nachrichten oder missgebildeten Paketen zwingt das Zielsystem zur Verlangsamung oder zum Absturz und zur Abschaltung, wodurch legitimen Benutzern oder Systemen der Dienst verweigert wird.

[6] Wie man DDoS-Angriffe verhindern kann

- Implementieren Sie Technologien und Tools, um **Netzwerke grafisch zu überwachen** und zu wissen, wie viel Bandbreite eine Website im Durchschnitt verbraucht. DDoS-Angriffe bieten **deutliche Anhaltspunkte**, so dass Administratoren, die das normale Verhalten ihrer Netzwerke verstehen, diese Angriffe besser erkennen können.
- Stellen Sie sicher, dass die **Server die Kapazität haben, um starke Verkehrsspitzen zu bewältigen**, und dass sie über die notwendigen Hilfsmittel zur Behebung von Sicherheitsproblemen verfügen.
- Aktualisieren und **patchen Sie Firewalls und Netzwerksicherheitsprogramme**.
- Erstellung von Protokollen**, in denen die im Falle eines DDoS-Angriffs zu ergreifenden Maßnahmen beschrieben sind.

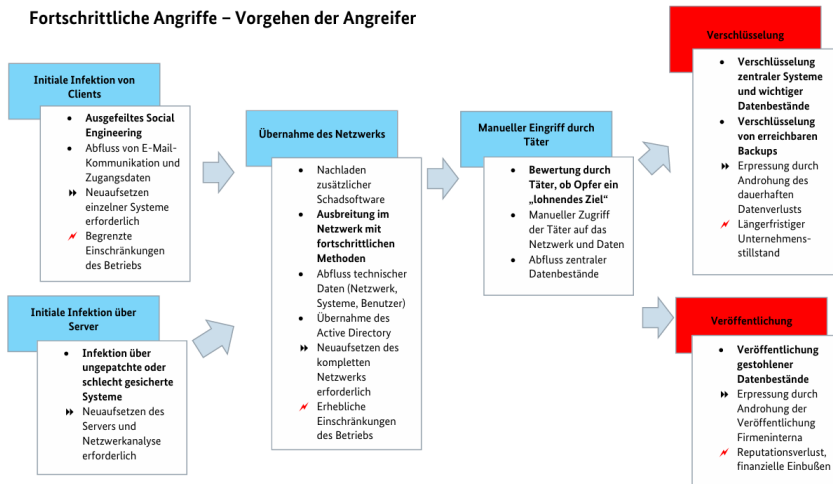
[7] Ransomware

- Der **Computer des Opfers wird gesperrt**, in der Regel durch Verschlüsselung, was das Opfer daran hindert, das Gerät oder die darauf gespeicherten Daten zu verwenden.
- Um wieder Zugriff auf das Gerät oder die Daten zu erhalten, muss das Opfer dem Hacker ein **Lösegeld** zahlen, in der Regel in einer virtuellen Währung wie Bitcoin.
- Ransomware kann über **bösartige E-Mail-Anhänge, infizierte Softwareanwendungen, infizierte externe Speichergeräte und kompromittierte Websites** verbreitet werden.

[7] Schutz vor Ransomware

- Unternehmen **regelmäßig Sicherungskopien** ihrer Computer erstellen und alle Software, einschließlich Antiviren-Software, aktualisieren.
- Anwender sollten es vermeiden, auf **Links in E-Mails zu klicken oder E-Mail-Anhänge von unbekannten Quellen** zu öffnen.
- Die Opfer sollten alles tun, um **die Zahlung von Lösegeld zu vermeiden**.
- Unternehmen sollten außerdem eine **herkömmliche Firewall**, die den unbefugten Zugriff auf Computer oder Netzwerke blockiert, mit einem Programm kombinieren, das **Webinhalte filtert** und sich auf Websites konzentriert, die möglicherweise Malware einschleusen.
- Außerdem sollte man den Datenzugriff von Cyberkriminellen einschränken, indem man das **Netzwerk in verschiedene Zonen** aufteilt, für die jeweils unterschiedliche Anmeldedaten erforderlich sind.

Fortschrittliche Angriffe – Vorgehen der Angreifer



23

[8] Exploit-Kits

Ein Exploit-Kit ist ein **Programmierwerkzeug, mit dem eine Person, die keine Erfahrung im Schreiben von Softwarecode hat**, Malware erstellen, anpassen und verbreiten kann.

- Exploit-Kits sind unter verschiedenen Namen bekannt, darunter Infection Kit, Crimeware Kit, DIY Attack Kit und Malware Toolkit.
- Cyberkriminelle nutzen diese Toolkits, um **Systemschwachstellen anzugreifen und Malware zu verbreiten** oder andere böswillige Aktivitäten durchzuführen, zum Beispiel den Diebstahl von Unternehmensdaten, Denial-of-Service-Angriffe oder den Aufbau von Botnets.

24

[8] Sich vor den Folgen von Exploit-Kits schützen

- Unternehmen **Anti-Malware-Software sowie ein Sicherheitsverfahren etablieren**, mit dem kontinuierlich geprüft wird, ob die Sicherheitskontrollen wirksam sind und Schutz vor Angriffen bieten.
- Unternehmen sollten auch **Anti-Phishing-Tools installieren**, da viele Exploit-Kits Phishing oder kompromittierte Websites nutzen, um in das Netzwerk einzudringen.

[9] Advanced Persistent Threats (APT)

Eine fortgeschrittene, anhaltende Bedrohung (Advanced Persistent Threat, APT) ist ein gezielter Cyberangriff, bei dem ein unbefugter Eindringling **in ein Netzwerk eindringt und über einen längeren Zeitraum unentdeckt bleibt**.

- Ziel eines APT-Angriffs ist es nicht, ein System oder Netzwerk zu beschädigen, sondern die Netzwerkaktivitäten zu überwachen und Informationen zu stehlen, um sich Zugang zu verschaffen, einschließlich Exploit-Kits und Malware.
- Cyberkriminelle nutzen APT-Angriffe in der Regel, um hochwertige Ziele wie große Unternehmen und Nationalstaaten anzugreifen und über einen langen Zeitraum Daten zu stehlen.

[9] Wie man sich vor APT-Angriffen schützt

- **Erkennung von Anomalien in ausgehenden Daten** kann für Systemadministratoren die beste Möglichkeit sein, um festzustellen, ob ihre Netzwerke angegriffen wurden.
 - **ungewöhnliche Aktivitäten auf Benutzerkonten**
 - **umfangreiche Verbreitung von Backdoor-Trojaner-Malware**, eine Methode, die es APTs ermöglicht, sich Zugang zu verschaffen
 - **merkwürdige Datenbankaktivitäten**, wie zum Beispiel eine plötzliche Zunahme von Datenbankoperationen mit großen Datenmengen
 - das **Vorhandensein ungewöhnlicher Datendateien**, die möglicherweise darauf hinweisen, dass Daten in Dateien gebündelt wurden, um den Exfiltrationsprozess zu unterstützen.
- Um diese Art von Bedrohung der Informationssicherheit zu bekämpfen, sollte ein Unternehmen auch eine **Software-, Hardware- oder Cloud-Firewall** zum Schutz vor APT-Angriffen einsetzen.
- Unternehmen können auch eine **Web Application Firewall** einsetzen, um Angriffe aus Webanwendungen zu erkennen und zu verhindern, indem sie den HTTP-Datenverkehr untersuchen.

[10] Malvertising

Malvertising ist eine Technik, mit der Cyberkriminelle **bösartigen Code in legitime Online-Werbenetzwerke und -Webseiten** einschleusen.

- Dieser Code **leitet die Nutzer in der Regel auf bössartige Websites** um oder installiert Malware auf ihren Computern oder Mobilgeräten.
- Die Computer der Benutzer können **infiert werden, auch wenn sie nicht auf etwas klicken**, um den Download zu starten.
- Cyberkriminelle können Malvertising nutzen, um eine Vielzahl von Malware zu installieren, mit der sich Geld verdienen lässt, darunter Krypto-Mining-Skripte, Ransomware und Banking-Trojaner.

[10] Malvertising

- Werbenetzwerke eine **Validierung einbauen**; dies verringert die Wahrscheinlichkeit, dass ein Nutzer kompromittiert werden könnte.

Die Validierung könnte Folgendes umfassen:

- Überprüfung potenzieller Kunden, indem legale Geschäftspapiere verlangt werden
- Zwei-Faktor-Authentifizierung
- Scannen potenzieller Anzeigen auf bösartige Inhalte vor der Veröffentlichung einer Anzeige
- möglicherweise **Umwandlung von Flash-Anzeigen** in animierte Gifs oder andere Arten von Inhalten
- Webhoster sollten ihre Websites **regelmäßig von einem ungepatchten System aus überprüfen** und dieses System überwachen, um bösartige Aktivitäten zu erkennen. Die Webhoster sollten alle bösartigen Anzeigen deaktivieren.
- Sicherheitsteams in Unternehmen sollten dafür sorgen, dass **Software und Patches auf dem neuesten Stand sind**, und Antimalware-Tools im Netzwerk installieren.

6 Traits of Malvertising



Was ist Cybersecurity?

<https://www.fortinet.com/de/resources/cyberglossary/what-is-cybersecurity>

Was ist Cybersecurity?

Verstehen Sie die verschiedenen Arten der Cybersecurity und die wichtigsten Formen von Cyber-Bedrohungen.

PROGNOSEN ZU CYBERBEDROHUNGEN FÜR 2025 BERICHT ZUR BEDROHUNGSLANDSCHAFT 2025

Definition Entwicklung der Cybersecurity Arten der Cybersecurity Cybersecurity Best Practices Häufig gestellte Fragen (FAQ)

Cybersecurity definiert

Cybersecurity ist eine Reihe von Standards und Praktiken, die Unternehmen zum Schutz ihrer Anwendungen, Daten, Programme, Netzwerke und Systeme vor Cyberangriffen und unbefugtem Zugriff verwenden. Cybersecurity-Bedrohungen nehmen schnell zu, da Angreifer neue Techniken und Social Engineering einsetzen, um Geld von Unternehmen und Benutzern zu erpressen, Geschäftsprozesse zu stören und sensible Informationen zu stehlen oder zu vernichten.

Um sich vor diesen Aktivitäten zu schützen, benötigen Unternehmen Technologie-Cybersecurity-Lösungen und einen robusten Prozess, um Bedrohungen zu erkennen und zu verhindern und eine Cybersecurity-Verletzung zu beheben.

Wie funktioniert Cybersecurity?

Cybersecurity-Ressourcen

- Cybersecurity
- Arten von Cyberangriffen
- IT- und OT-Cybersecurity
- KI-Cybersecurity
- Cyber Threat Intelligence
- Cybersecurity-Management
- Netzwerksicherheit
- Datensicherheit
- E-Mail-Sicherheit
- Endpoint-Security
- Web Security

Need help?